

# An OWL-Based Ontology for NIS2 Article 21 Compliance

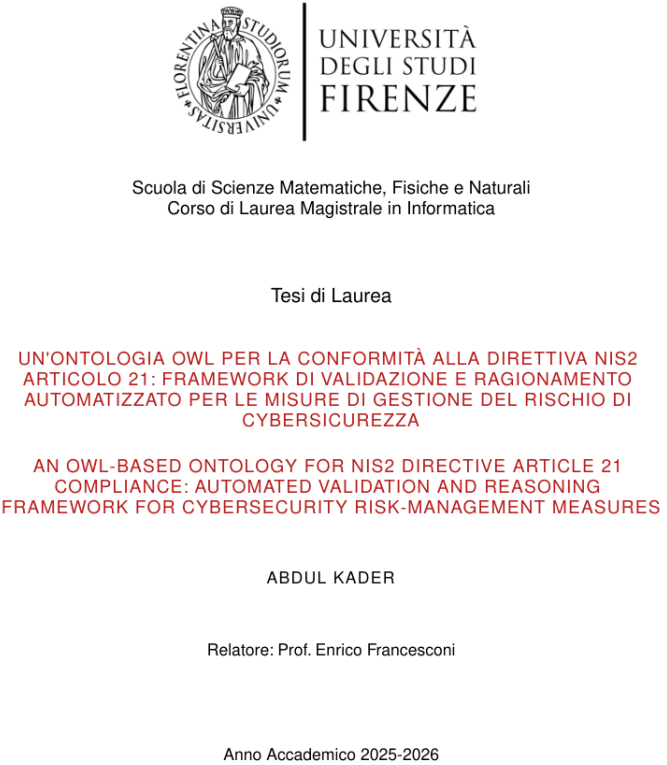
Automated validation and reasoning for cybersecurity risk-management measures.

- Candidate: Abdul Kader
- Supervisor: Prof. Enrico Francesconi
- Focus: problem, approach, outcome, and limits

OWL 2 DL

SHACL

SPARQL



Thesis cover page from the dissertation

# Problem and objective

Why this thesis exists

- NIS2 Article 21 defines multiple technical, operational, and organizational measures.
- In practice, compliance checking is often manual and document-driven.
- That makes verification slow, inconsistent, and hard to reproduce.
- The objective is to make Article 21 compliance machine-readable and explainable.

## What the thesis contributes

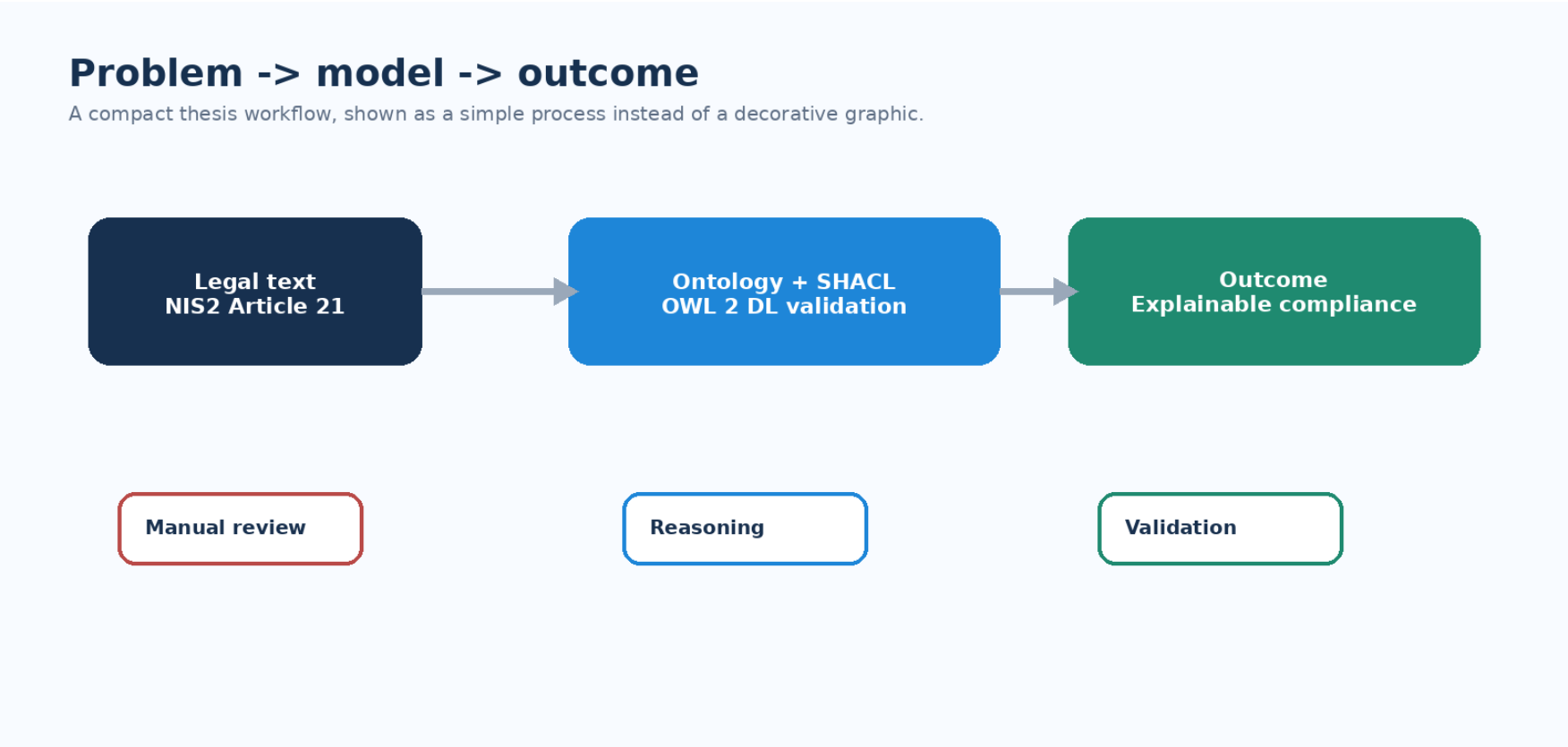
- An OWL 2 DL ontology for Article 21(2) requirements.
- A compliance class inferred from implemented measures.
- SHACL validation for missing or incomplete evidence.
- A compact web application for querying and visualization.

## Goal

Turn legal obligations into a formal model that can be checked, queried, and explained.

# Approach

From legal text to computable compliance



Simple thesis workflow: legal text -> ontology -> validation -> outcome

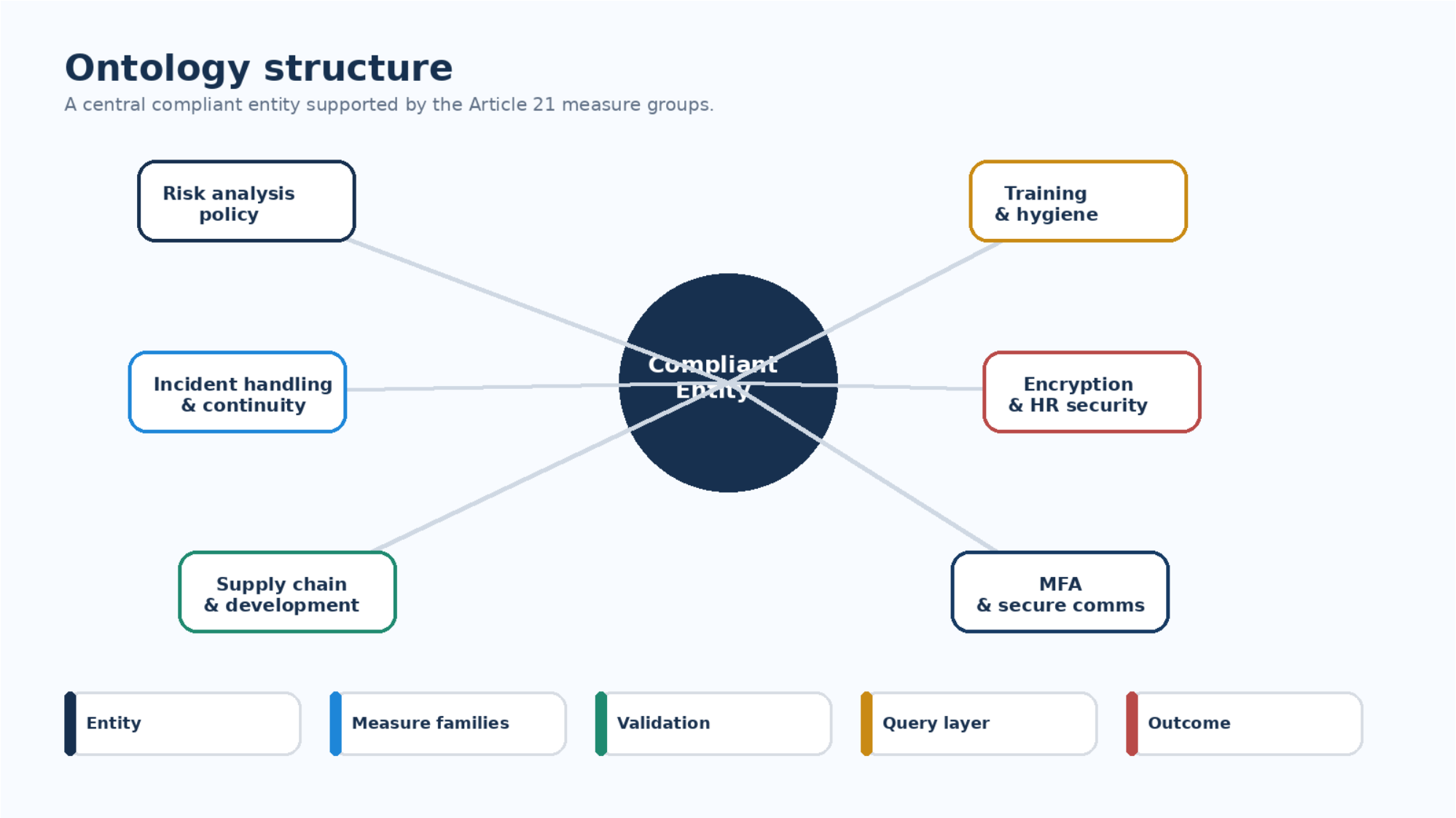
- Design-science approach: build the artifact, then evaluate it.
- The model uses OWL for meaning and inference.
- SHACL checks whether required evidence is present.
- SPARQL supports inspection and lightweight reporting.

**Design choice**

The thesis models the ten legal points as twelve operational classes, splitting point (g) and point (j) where the legal text bundles separate concerns.

# Ontology model

The structure that makes compliance computable



Ontology structure with a central compliance entity and the required measure groups

## Key classes

- Entity and RiskManagementMeasure
- Technical, Operational, Organizational measures
- CybersecurityRisk and SecurityIncident
- SecurityStandard and NetworkInformationSystem

## Why it matters

- Keeps legal provenance visible.
- Lets the reasoner infer compliance classes.
- Supports explanation, not just a binary result.

# Validation and results

What the prototype demonstrates

| Art. 21(2) | Legal obligation (abbreviated)                            | State of affair                             | Verdict   |
|------------|-----------------------------------------------------------|---------------------------------------------|-----------|
| (a)        | Risk analysis and information system security policies    | Med Center Risk Analysis Policy implemented | COMPLIANT |
| (b)        | Incident handling procedures and capabilities             | Med Center Incident Handling implemented    | COMPLIANT |
| (c)        | Business continuity, backup management, disaster recovery | No measure asserted                         | VIOLATION |
| (d)        | Supply chain security and supplier relationships          | No measure asserted                         | VIOLATION |
| (e)        | Security in NIS acquisition, development and maintenance  | No measure asserted                         | VIOLATION |
| (f)        | Policies to assess effectiveness of risk measures         | No measure asserted                         | VIOLATION |
| (g)        | Basic cyber hygiene practices and training                | Basic Cyber Hygiene + Training Awareness    | COMPLIANT |
| (h)        | Policies regarding cryptography and encryption            | Med Center Encryption implemented           | COMPLIANT |
| (i)        | Human resources security, access control, asset mgmt      | No measure asserted                         | VIOLATION |
| (j)        | MFA / continuous authentication + secured communications  | MFA only; no Secure Communications          | PARTIAL   |

Article 21(2)(j) warrants special attention: the ontology decomposes this norm into two operational classes — MultiFactorAuthentication and SecureCommunications — because the directive text covers both authentication solutions and secured voice/video/text communications. MedCenterHospital satisfies the authentication component but not the communications component. The ontology makes this decomposition explicit, allowing the compliance verdict to distinguish between two obligations encoded within a single legal paragraph.

- 8.14.7 Compliance Verdict and Remediation Path**  
The formal verification of MedCenterHospital against the NIS2 Article 21 ontology yields the following outcome:
- OWL 2 DL inferred classification: :NonCompliantEntity
  - SHACL result: INVALID — 6 sh:Violation, 0 sh:Warning on implemented measures

Worked example from the thesis showing the partial healthcare case and verdicts

## Observed outcome

12 / 12

Full coverage leads to the inferred `CompliantEntity` class.

6 / 12

Partial coverage stays non-compliant and makes the gaps visible.

## Interpretation

- The score is coverage, not certification.
- Each missing category is named explicitly.
- This keeps legal judgment separate from the model.

# Comparison and limitations

Where this thesis is useful, and where it stops

### 9.5 Comparison with Existing Approaches

The implemented framework is compared against three categories of existing approaches:

| Approach                     | Formal Semantics | Auto Reasoning | SPARQL | SHACL | Open Source |
|------------------------------|------------------|----------------|--------|-------|-------------|
| This thesis (OWL+SHACL)      | Yes (OWL 2 DL)   | Yes            | Yes    | Yes   | Yes         |
| Commercial GRC tools         | No               | No             | No     | No    | No          |
| ENISA checklist              | No               | No             | No     | No    | Yes         |
| Hassan 2025 (Legal Ontology) | Yes (OWL 2 DL)   | Yes            | Yes    | No    | Yes         |
| Manual audit                 | No               | No             | No     | No    | N/ A        |

The comparison shows that the prototype combines several capabilities in one demonstrator. It should not be read as evidence that it is more complete than every commercial or academic alternative, because the compared categories differ in scope, evidence management, workflow, assurance, and production maturity.

### 9.6 Competency-Question Evaluation

All five competency questions can be expressed using the ontology vocabulary and executed through the query interface. Returned bindings correspond to manually inspected triples and expected inference paths.

This confirms functional adequacy for the declared information needs and demonstrates that the conceptual model supports risk, standard, incident, system, and implementation analysis.

The selected questions use a bounded query subset and do not establish complete SPARQL 1.1 conformance.

### 9.7 Error Analysis and Negative Cases

The incomplete asserted entity produces seven expected missing-class results rather than a generic failure. Additional partial cases can be generated through /api/check-entity.

Specific reporting supports diagnosis and remediation. The observed SHACL-oriented violations correspond to the absent operational classes in the tested graph.

The small synthetic dataset cannot estimate behavior under noisy data, inconsistent typing, duplicate controls, or disputed mappings.

## Strength

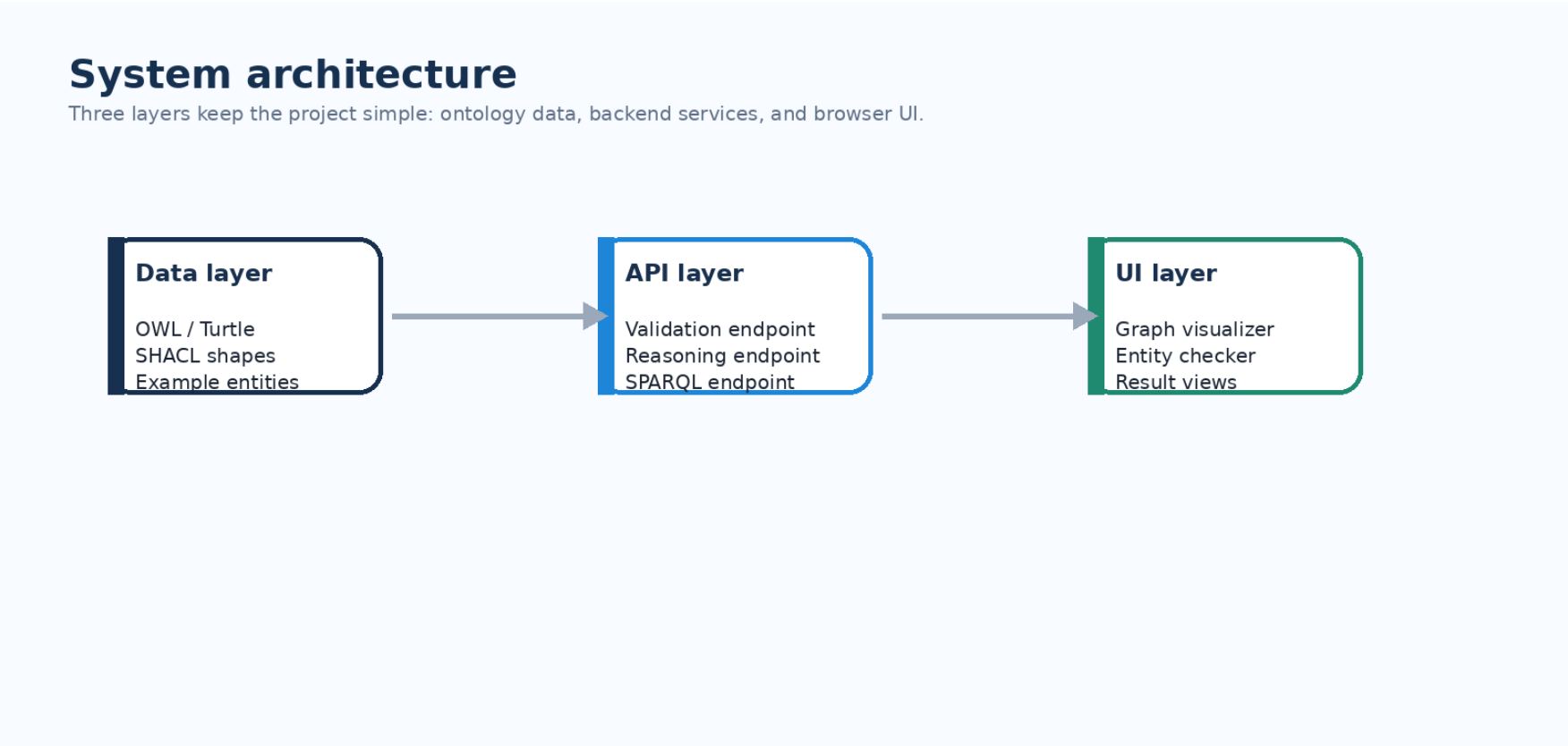
- Formal semantics with OWL 2 DL
- Validation with SHACL
- Queryable with SPARQL

## Limitations

- Prototype reasoning is bounded.
- Not a full production compliance system.
- Evidence and governance remain future work.

# System view

The implementation stays compact



Three-tier view of the thesis project: data, API, and UI

- The ontology is stored as RDF/OWL and loaded by the backend.
- The API exposes validation, reasoning, and ontology data endpoints.
- The browser UI is for graph exploration and quick compliance checks.

# Research questions

What the thesis set out to answer

## Research questions

The presentation should answer these three things early and clearly.

**Can Article 21(2) be represented  
as a layered ontology?**

**Which OWL axiom pattern best captures  
compliance coverage?**

**How do SHACL and OWL complement  
one another?**

Three research questions presented early, in a compact academic style

- RQ1: represent Article 21(2) as a layered ontology.
- RQ2: define an OWL axiom pattern for compliance coverage.
- RQ3: combine SHACL validation with OWL reasoning.

# Technology stack

A small, standard toolchain

## Technology stack

The thesis uses a small, standard stack rather than a heavy custom system.



### Why this matters

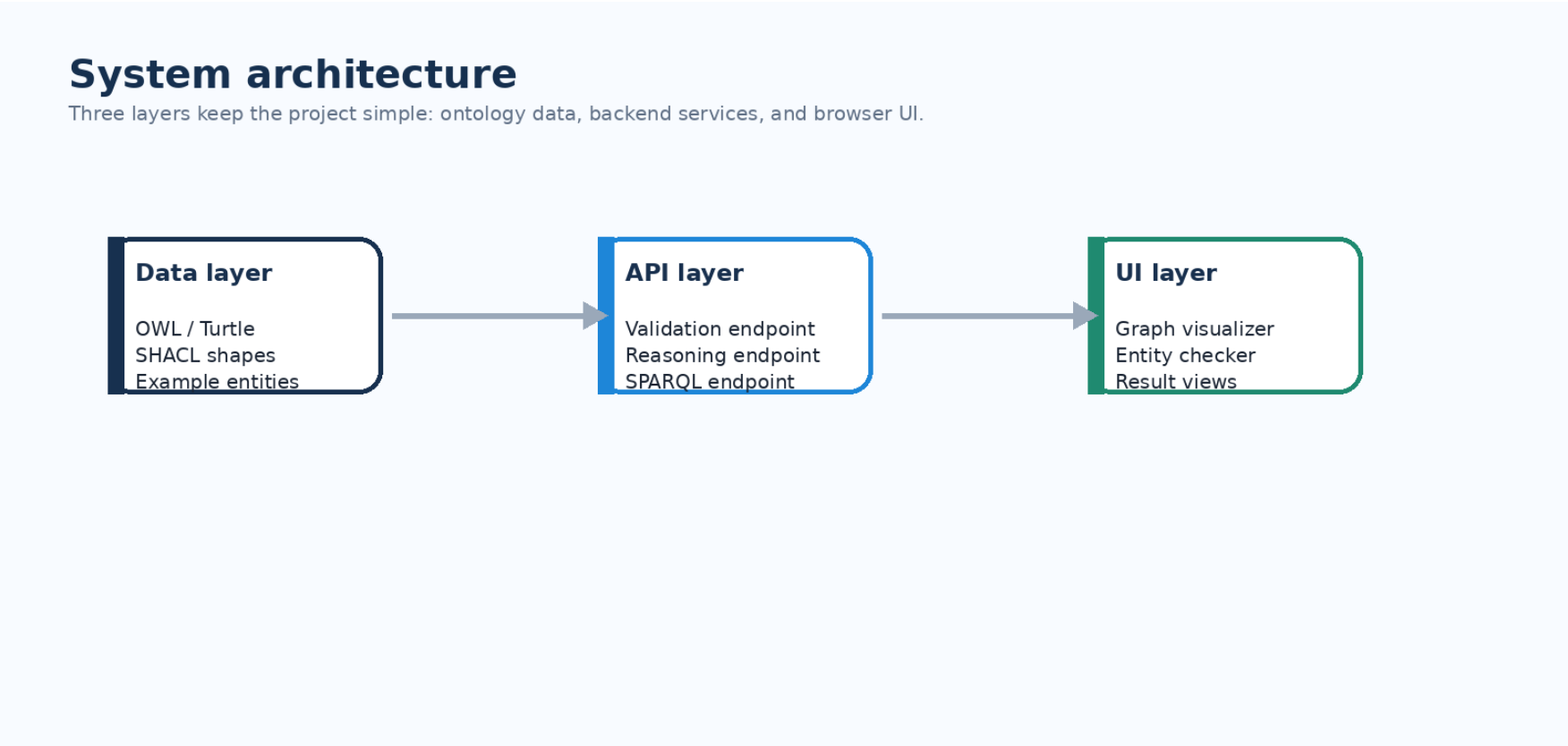
A small stack keeps the thesis reproducible, standard-based, and easier to explain in a defense.

OWL, Protégé, SHACL, SPARQL, and a small Express backend

- The stack is standard and reproducible.
- It keeps the thesis grounded in Semantic Web tooling.
- It avoids unnecessary custom infrastructure.

# Prototype view

What the user can actually inspect



Three-tier implementation used by the thesis prototype

**Practical takeaway**

The prototype is intentionally small: it loads the ontology, exposes validation and reasoning endpoints, and presents the result in a browser-friendly view.

# Conclusion

Use this as your final one-minute summary

## Takeaway

This thesis shows that NIS2 Article 21 compliance can be represented as a formal ontology, validated with shapes, queried with SPARQL, and explained through a small web application.

## What to say out loud

- The problem is manual and inconsistent verification.
- The solution is a machine-readable, traceable ontology.
- The result is clear gap detection and explainable outcomes.

Thank you



Thesis cover

# Future work

A sensible closing slide for the defense

## Next steps

- Connect the prototype to a standards-complete reasoner.
- Add evidence, provenance, and review metadata.
- Extend the model beyond Article 21 to other NIS2 duties.
- Test the system with realistic data and user feedback.

### 9.5 Comparison with Existing Approaches

The implemented framework is compared against three categories of existing approaches:

| Approach                     | Formal Semantics | Auto Reasoning | SPARQL | SHACL | Open Source |
|------------------------------|------------------|----------------|--------|-------|-------------|
| This thesis (OWL+SHACL)      | Yes (OWL 2 DL)   | Yes            | Yes    | Yes   | Yes         |
| Commercial GRC tools         | No               | No             | No     | No    | No          |
| ENISA checklist              | No               | No             | No     | No    | Yes         |
| Hassan 2025 (Legal Ontology) | Yes (OWL 2 DL)   | Yes            | Yes    | No    | Yes         |
| Manual audit                 | No               | No             | No     | No    | N/ A        |

The comparison shows that the prototype combines several capabilities in one demonstrator. It should not be read as evidence that it is more complete than every commercial or academic alternative, because the compared categories differ in scope, evidence management, workflow, assurance, and production maturity.

### 9.6 Competency-Question Evaluation

All five competency questions can be expressed using the ontology vocabulary and executed through the query interface. Returned bindings correspond to manually inspected triples and expected inference paths.

This confirms functional adequacy for the declared information needs and demonstrates that the conceptual model supports risk, standard, incident, system, and implementation analysis.

The selected questions use a bounded query subset and do not establish complete SPARQL 1.1 conformance.

### 9.7 Error Analysis and Negative Cases

The incomplete asserted entity produces seven expected missing-class results rather than a generic failure. Additional partial cases can be generated through /api/check-entity.

Specific reporting supports diagnosis and remediation. The observed SHACL-oriented violations correspond to the absent operational classes in the tested graph.

The small synthetic dataset cannot estimate behavior under noisy data, inconsistent typing, duplicate controls, or disputed mappings.

A concise reminder that the thesis combines semantics, validation, and querying

### Closing point

The thesis is strongest as a formal compliance framework and demonstration, not as a finished production system.